MTRO. JOSE DE JESUS SOTO SANCEZ
MAESTRÍA EN SEGURIDAD INFORMÁTICA
CONSULTOR EN CIBERSEGURIDAD

UNIDAD TEMATICA 1

FUNDAMENTOS DE CIBERSEGURIDAD

Fundamentos de Redes y Criptografía Aplicada



UNIVERSIDAD DE GUADALAJARA
Red Universitaria e Institución Benemérita de Jalisco

CUCEI
CENTRO UNIVERSITARIO DE CIENCIAS EXACTAS E INGENIERÍAS

UNIVERSIDAD DE GUADALAJARA
Red Universitaria e Institución Benemérita de Jalisco

CUCEI
CENTRO UNIVERSITARIO DE CIENCIAS EXACTAS E INGENIERÍAS

Introducción a la Ciberseguridad

Conceptos fundamentales, evolución histórica e importancia en la sociedad digital actual

- Conceptos
- Evolución Histórica
- Impacto Económico

CONCEPTO Y SU EVOLUCIÓN

Concepto de Ciberseguridad y su Evolución

Definición

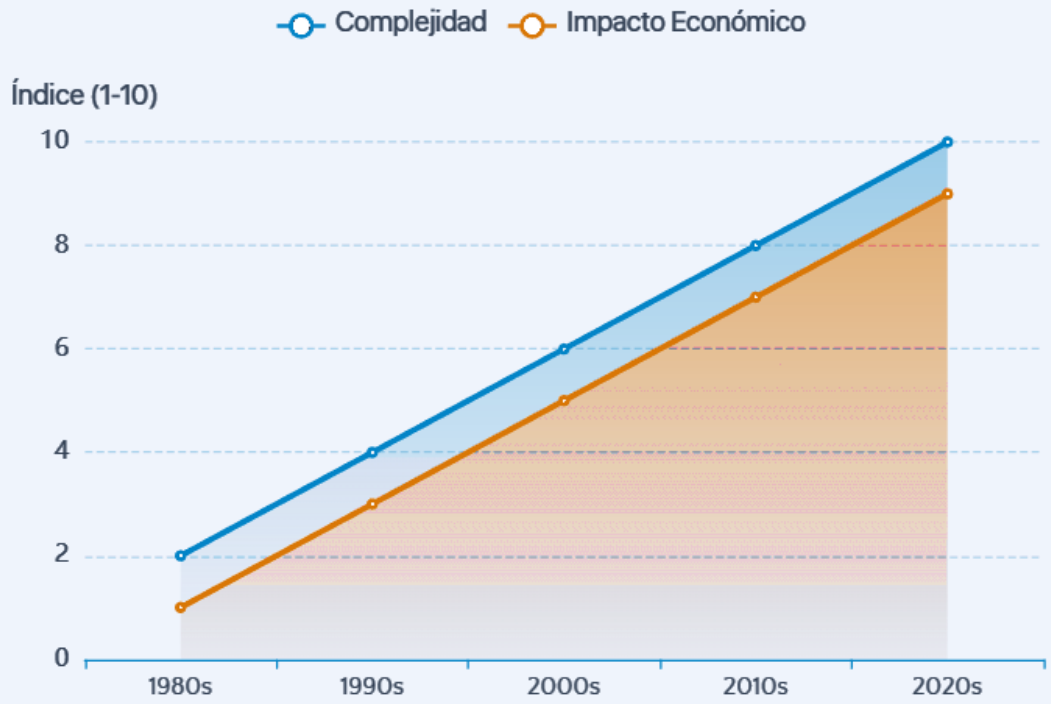
La ciberseguridad es la práctica de proteger **sistemas, redes, aplicaciones y datos** contra accesos no autorizados, uso indebido o interrupciones. Comprende defensas técnicas y procesos estratégicos para reducir el riesgo y garantizar entornos digitales seguros.

> "La ciberseguridad no es un producto, sino un proceso continuo de gestión de riesgos"
>
> — Bruce Schneier

Hitos Clave

1988	**Morris Worm**	Primer gusano de Internet, afectó 6,000 PCs
2000	**ILOVEYOU**	Virus que se propagó por email
2010	**Stuxnet**	Gusano que atacó instalaciones nucleares
2017	**WannaCry**	Ransomware que afectó 150 países

Evolución de la Complejidad de Amenazas



Década 2000s

Amenazas Financieras

Phishing, spyware, botnets DDoS

Década 2020s

Amenazas con IA

Deepfakes, RaaS, ataques supply chain

IMPORTANCIA EN LA SOCIEDAD DIGITAL

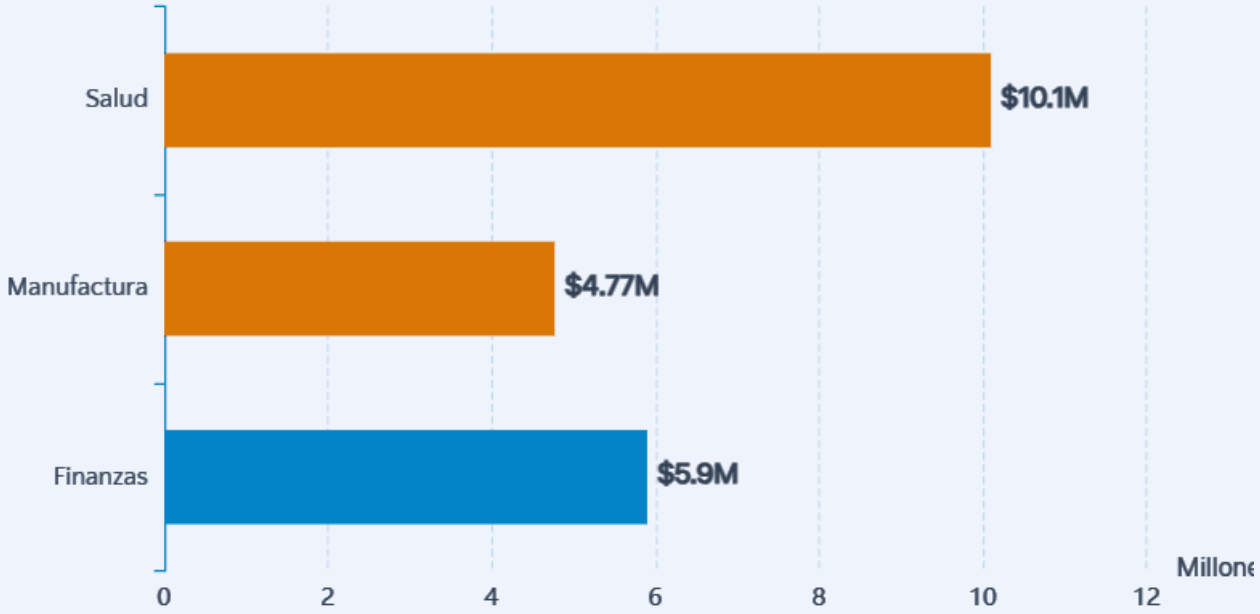
Impacto Económico de las Amenazas Cibernéticas

Pérdidas Globales Estimadas 2025

$10.5 Trillones

Duplicando pérdidas vs. 2023

Costo Promedio por Brecha por Sector (2024)



Costo por Minuto de Inactividad

$5,600

Incluye: pérdida de productividad, daños reputacionales, multas.

Tasa de Cierre de Pymes

60%

Pymes que cierran en <6 meses tras un ataque.

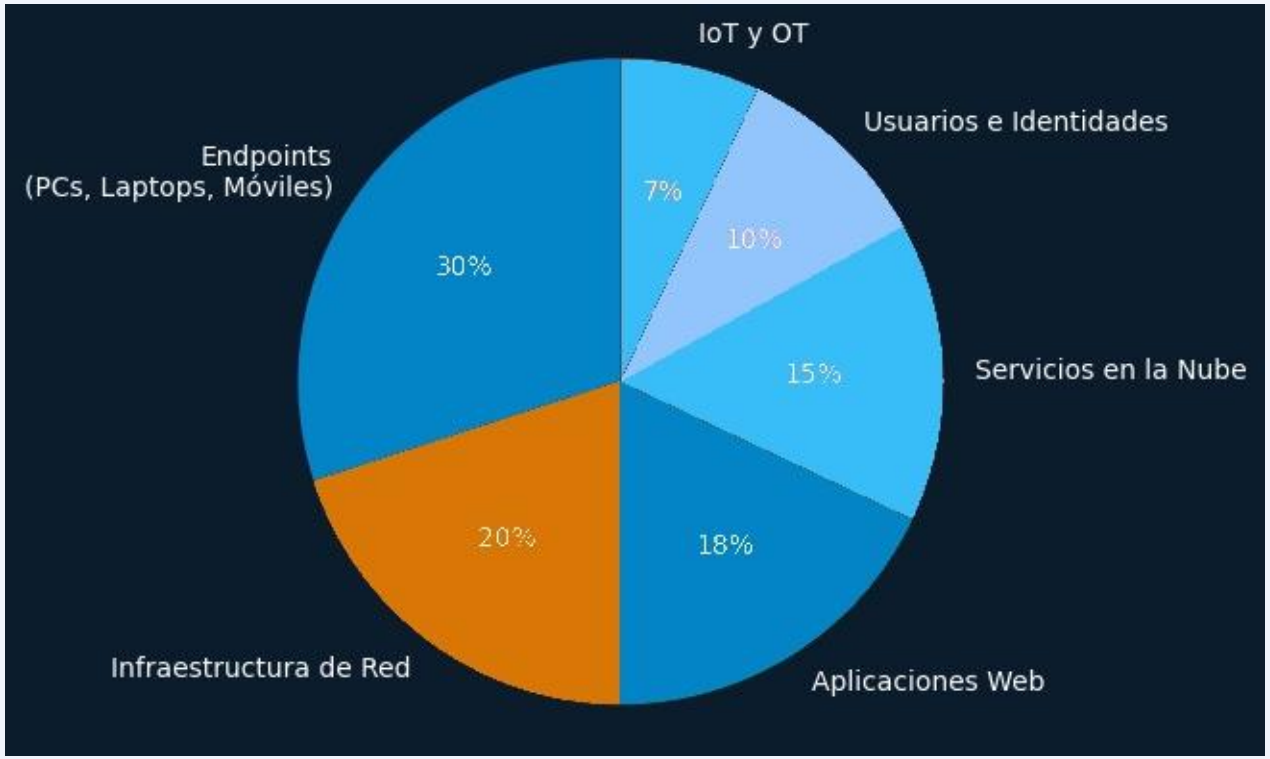
Factores de Costo

- **Multas:** GDPR, regulaciones locales.
- **Reputación:** pérdida de clientes.
- **Recuperación:** sistemas, investigación.
- **Inactividad:** interrupción de operaciones.

INFRAESTRUCTURA Y REDES

Relación con Redes e Infraestructura Tecnológica

Superficie de Ataque Ampliada



Dispositivos IoT Vulnerables

70%

de dispositivos IoT tienen vulnerabilidades críticas.

Tráfico sin cifrar	Firmware desactualizado
Alto	Crítico

Infraestructuras Críticas

Objetivos estratégicos con impacto nacional:

- Sector salud: +264% ataques ransomware
- Energía: potencial para daños físicos
- Finanzas: ataques a aplicaciones web

Ataques a Cadena de Suministro

+33% aumento en 2024. Ej: SolarWinds (2020).

UNIVERSIDAD DE GUADALAJARA
Red Universitaria e Institución Benemérita de Jalisco

CUCEI
CENTRO UNIVERSITARIO DE CIENCIAS EXACTAS E INGENIERÍAS

Principios Fundamentales

La **Triada CIA**: Confidencialidad, Integridad y Disponibilidad

- **Confidencialidad**
- **Integridad**
- **Disponibilidad**

CONFIDENCIALIDAD

Confidencialidad: Definición, Ejemplos y Controles

Definición

La confidencialidad es el principio de seguridad que **garantiza que la información solo sea accesible** para personas y sistemas autorizados. Su objetivo es prevenir la **divulgación no autorizada** de información sensible.

"La confidencialidad no es solo sobre quién puede ver los datos, sino quién necesita verlos."

Principio de Menor Privilegio

Los usuarios solo deben tener acceso a los recursos estrictamente necesarios para sus funciones.

- Acceso basado en roles (RBAC)
- Autenticación multifactor (MFA)
- Cifrado de datos en reposo y tránsito

Controles de Confidencialidad

Cifrado

AES-256, RSA-2048, TLS 1.3

Control de Acceso

RBAC, ACL, Zero Trust

Prevención de Pérdida

DLP, etiquetado, clasificación

Ejemplo: Sector Financiero

Protección de datos de clientes:

Cifrado de bases de datos	**AES-256**
Comunicaciones	**TLS 1.3**
Autenticación	**MFA**

74% de ataques afectan datos personales de clientes

INTEGRIDAD

Integridad: Definición, Amenazas y Mecanismos

Definición

La integridad es el principio que **garantiza que la información sea precisa, completa, auténtica y fiable** durante todo su ciclo de vida. Asegura que los datos no sean modificados de forma no autorizada, ya sea accidental o intencionalmente.

Amenazas a la Integridad

Ransomware
Cifra archivos, alterando su estado original

Modificación Maliciosa
Atacantes alteran datos para beneficio propio

Errores Humanos
Modificaciones accidentales por usuarios

Mecanismos de Protección

Firmas Digitales
RSA, DSA

Checksums
SHA-256, MD5

Logs de Auditoría
Tracking cambios

Versionado
Git, backups

Ejemplo: Registros Médicos

En hospitales, la integridad es crítica. Un registro alterado puede poner vidas en riesgo.

Estadística Crítica

+264% ataques ransomware

en sector salud últimos 5 años

- ✓ Logs inmutables de acceso a pacientes
- ✓ Checksums verifican integridad

DISPONIBILIDAD

Disponibilidad: Impacto Operativo y Continuidad

Definición

La disponibilidad asegura que **los datos y sistemas estén accesibles** para usuarios autorizados cuando los necesiten. Es crítico para operaciones de negocio continuoas.

"Los datos inaccesibles son tan valiosos como datos inexistentes."

Impacto Financiero

Costo por Minuto

$5,600

Incluye pérdida de productividad, transacciones fallidas, daño reputacional y costes de recuperación.

Métricas de Disponibilidad

99.9% ("Tres nueves")	8.76h
Downtime anual permitido	
99.99% ("Cuatro nueves")	52.6min
Downtime anual permitido	
99.999% ("Cinco nueves")	5.26min
Downtime anual permitido	

SLA: Service Level Agreement

Estrategias de Alta Disponibilidad

- **Redundancia**
  Sistemas duplicados
- **Clustering**
  Balanceo de carga
- **DRP**
  Plan de recuperación
- **Backups**
  Respaldos verificados

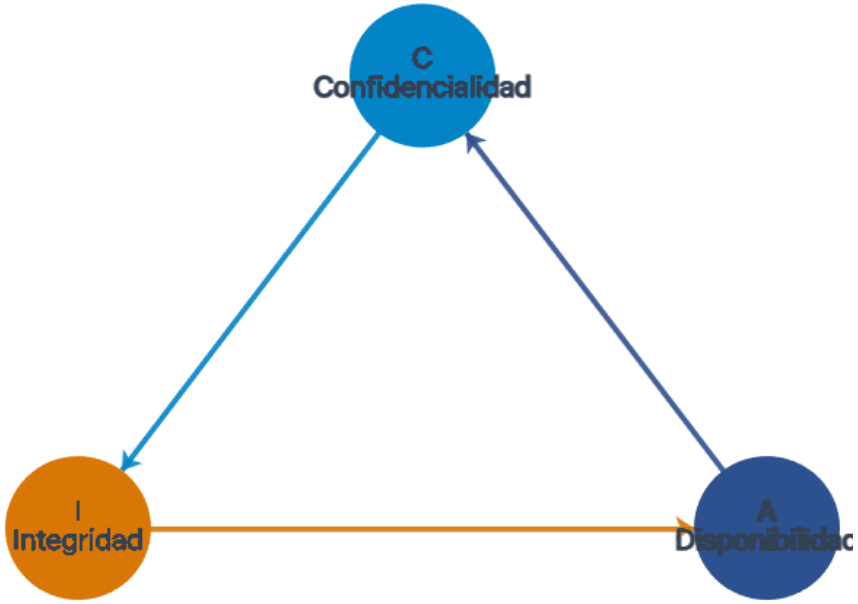
Objetivos de Recuperación

RPO
Punto de recuperación

RTO
Tiempo de recuperación

RELACIÓN ENTRE PRINCIPIOS

Interdependencia de los Principios CIA



Trade-offs: Balance de Seguridad

Los tres principios están interconectados. Aumentar uno puede afectar otros. El diseño de seguridad requiere balance entre protección y usabilidad.

> "Seguridad perfecta es inalcanzable; el objetivo es gestionar riesgos aceptablemente."

Cifrado Fuerte

+ Confidencialidad

- **Disponibilidad:** pérdida de claves = datos inaccesibles

Backups Frecuentes

+ Disponibilidad

- **Confidencialidad:** más copias = mayor superficie de ataque

Validaciones

+ Integridad

- **Disponibilidad:** verificaciones pueden causar delays

MFA Estricto

+ Confidencialidad

- **Disponibilidad:** fallos en segundo factor bloquean acceso

Modelo de Balance

C	I	A
Privacidad	Exactitud	Acceso



UNIVERSIDAD DE GUADALAJARA

Red Universitaria e Institución Benemérita de Jalisco

CUCEI

CENTRO UNIVERSITARIO DE CIENCIAS EXACTAS E INGENIERÍAS

Activos de Información

Clasificación de activos y **superficie de exposición**

- Activos Digitales
- Clasificación
- Superficie de Ataque
- Vulnerabilidades

CONCEPTO DE ACTIVO

¿Qué es un Activo de Información?

Definición

Un activo de información es **cualquier cosa que tenga valor para la organización** y requiera protección. No es solo hardware: incluye datos, servicios, reputación y personas.

> "No puedes proteger lo que no conoces. El inventario de activos es el primer paso en seguridad."

Criterios de Valoración

Criticidad
Impacto en operaciones si se compromete

Sensibilidad
Nivel de confidencialidad requerido

Valor Monetario
Costo de reemplazo o impacto económico

Legal/Regulatorio
Requisitos de cumplimiento aplicables

Tipos de Activos

Información
Datos, PII, secretos

Hardware
Servidores, endpoints

Software
Apps, SO, licencias

Servicios
APIs, cloud, SaaS

Personas
Empleados clave

Procesos
Procedimientos

Ejemplos de Activos Críticos

- Base de datos de clientes
- Código fuente propietario
- Contratos y acuerdos
- Infraestructura cloud

CLASIFICACIÓN DE ACTIVOS

Esquemas de Clasificación y Niveles de Seguridad

Esquema de Clasificación

Clasificar activos por **nivel de sensibilidad** permite aplicar controles proporcionales. No todos los datos requieren la misma protección.

> "Clasificación de datos es el fundamento de una estrategia de seguridad efectiva."

Criterios de Clasificación

- Sensibilidad
- Impacto de divulgación
- Requisitos legales

Niveles de Clasificación

Público

BAJO

Información de dominio público. Divulgación no causa daño.

Ejemplos: Marketing, precios públicos

Interno

MEDIO

Uso interno. Divulgación limitada causa daño menor.

Ejemplos: Políticas internas, documentos operacionales

Confidencial

ALTO

Acceso restringido. Divulgación causa daño significativo.

Ejemplos: Datos de clientes, estrategia comercial

Secreto

CRÍTICO

Acceso ultra-restringido. Divulgación causa daño severo.

Ejemplos: Secretos comerciales, código fuente, datos médicos

SUPERFICIE DE ATAQUE

Superficie de Ataque y Superficie de Exposición

Definiciones

Superficie de Ataque

Suma de todos los puntos de entrada vulnerables de un sistema.

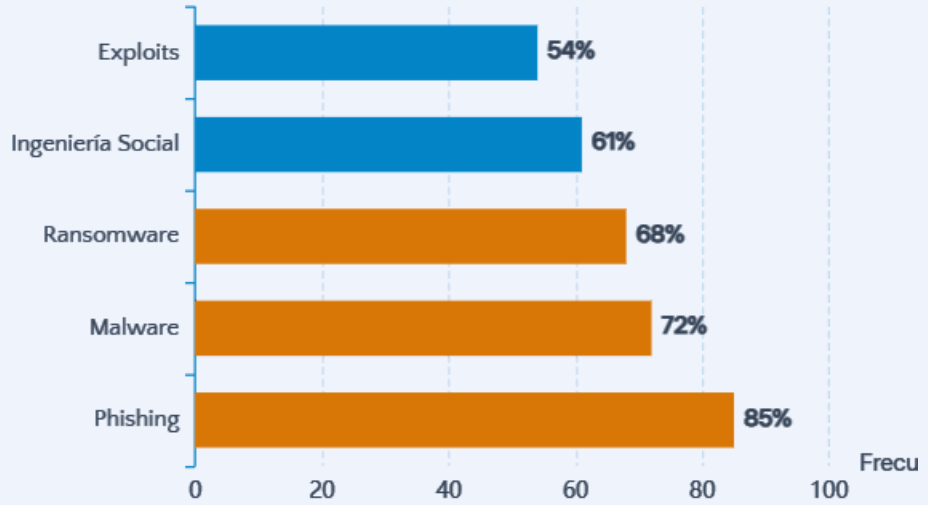
Superficie de Exposición

Activos accesibles desde Internet. Reducirla = menos riesgo.

Gestión ASM (5 Pasos)

1. Mapeo de superficie
2. Eliminación de activos
3. Evaluación de vulnerabilidades
4. Priorización de riesgos
5. Mitigación de debilidades

Vectores de Ataque Comunes



Cadena de Suministro

+33%

aumento ataques 2024

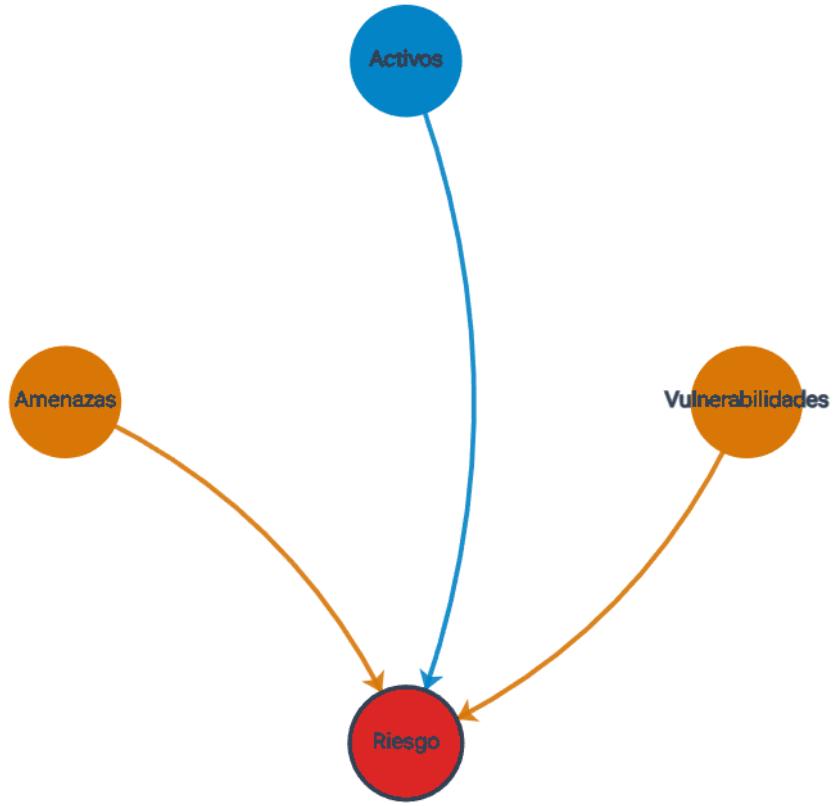
Reducción de Superficie

Menor superficie = menor riesgo

- ✓ Cerrar puertos innecesarios
- ✓ Desactivar servicios
- ✓ Segmentar red

MODELO DE RIESGO

Relación entre Activos, Amenazas y Vulnerabilidades



Fórmula del Riesgo

$$RIESGO = A \times V \times I$$

Activo × Vulnerabilidad × Impacto

El riesgo existe cuando una amenaza puede explotar una vulnerabilidad para afectar un activo.

Ejemplo Práctico

Activo: Servidor web

Amenaza: Ransomware

Vulnerabilidad: S. desactualizado

Riesgo: Cifrado de datos

Matriz de Riesgo

Probabilidad vs Impacto

B	B	M	M	A
B	M	M	A	C
M	M	A	C	C
M	A	C	C	C
A	C	C	C	C

B=Bajo M=Medio A=Alto C=Crítico

Proceso de Evaluación

1	2	3
Activos críticos	Amenazas	Vulnerabilidades



UNIVERSIDAD DE GUADALAJARA

Red Universitaria e Institución Benemérita de Jalisco

CUCEI

CENTRO UNIVERSITARIO DE CIENCIAS EXACTAS E INGENIERÍAS

Amenazas Tecnológicas

Malware, ingeniería social y **vulnerabilidades**

- Malware
- Phishing
- Ransomware
- APTs

CONCEPTO DE AMENAZA Y ACTORES

Amenazas en Ciberseguridad: Definición y Actores

Definición

Una amenaza es **cualquier circunstancia o evento con potencial de causar daño** a los activos de información. Representa el "quién" o "qué" puede explotar vulnerabilidades.

> "Las amenazas son constantes; la preparación es opcional."

Tipos de Amenazas

Naturales
Desastres ambientales

Humanas
Acciones intencionales o accidentales

Técnicas
Fallos de hardware/software

Evolución de Amenazas

Infostealers (2024)	+500%
Malware (H1 2024)	+30%
Amenazas cifradas	+92%

CONCEPTO DE AMENAZA Y ACTORES

Actores de Amenazas Cibernéticas

Quién está detrás de los ataques y por qué

Ciberdelincuentes

Motivación: Lucro económico. Grupos organizados que operan como empresas criminales.

Tácticas: Ransomware, phishing, BEC, fraude online.

Insiders (Amenazas Internas)

Motivación: Venganza, lucro, negligencia. Empleados actuales o pasados.

Tácticas: Robo de datos, sabotaje, acceso no autorizado.

Hacktivistas

Motivación: Activismo político/social. Buscan atención pública y cambio.

Tácticas: DDoS, defacements, doxxing, campañas de boicot.

Script Kiddies

Motivación: Reconocimiento, diversión. Poca habilidad técnica.

Tácticas: Herramientas pre-construidas, DDoS básicos.

APT (Estados-Nación)

Motivación: Espionaje geopolítico, sabotaje, robo de IP. Grupos sofisticados.

Tácticas: Zero-days, spear phishing, persistencia avanzada.

Organizaciones Criminales

Motivación: Escala industrial de fraude y extorsión. Estructura empresarial.

Tácticas: Ransomware como servicio (RaaS), BEC a gran escala.

Perfil del Atacante: Comprender las motivaciones y capacidades de los actores de amenazas es esencial para implementar las contramedidas adecuadas y anticipar vectores de ataque.

MALWARE

Tipos de Malware: Taxonomía y Objetivos

Taxonomía de Malware

Virus
Se adhiere a archivos. Requiere acción del usuario.

Gusanos
Se autorreplican. Se propagan solos por redes.

Troyanos
Disfrazados de software legítimo. Abren puertas traseras.

Ransomware
Cifra archivos y exige rescate. Objetivo: lucro.

Spyware
Espía actividades del usuario. Roba credenciales.

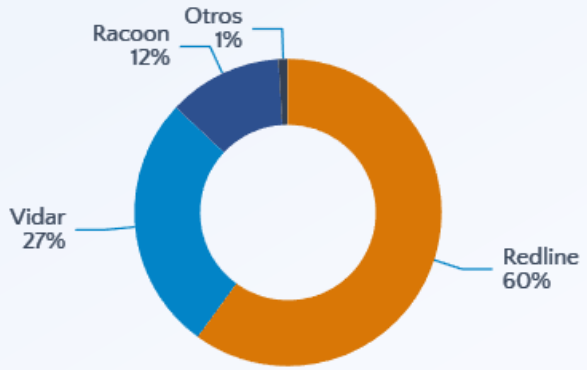
Rootkits
Ocultan presencia. Control total del sistema.

Keyloggers
Registran pulsaciones de teclado. Roban contraseñas.

Adware
Muestra anuncios no deseados. Ralentiza el sistema.

Fileless
Ejecuta en RAM. Difícil de detectar.

Distribución de Malware 2024



Objetivos del Malware

- $ Robo económico
- Exfiltración de datos
- Sabotaje
- Creación de botnets

INGENIERÍA SOCIAL

Ingeniería Social y Phishing: Manipulación Psicológica

Definición

La ingeniería social explota **psicología humana**, no vulnerabilidades técnicas. Manipula emociones para obtener información.

Técnicas Comunes

Phishing

Correo masivo. Suplantación de identidad.

Spear Phishing

Dirigido a objetivos específicos. 91% de ataques.

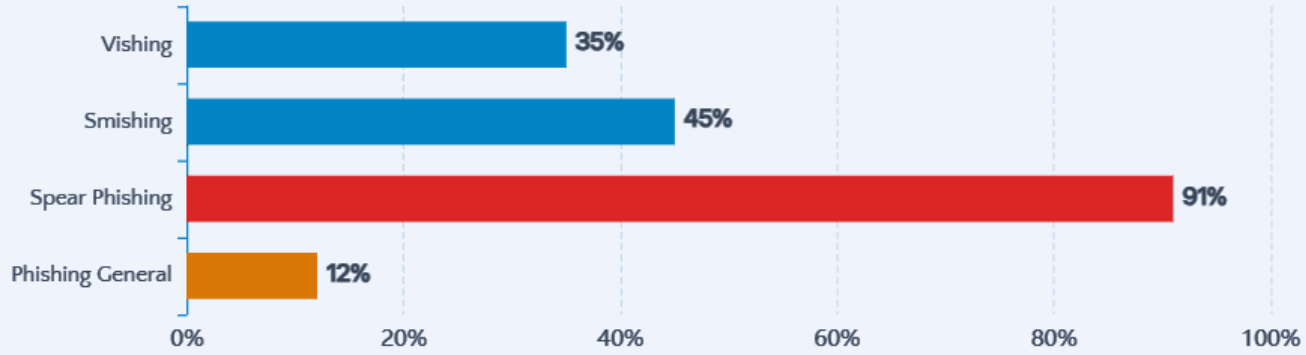
Vishing

Phishing de voz. Suplantación de entidades.

Smishing

Por SMS. Alta tasa de apertura.

Efectividad del Phishing



30%	12%	56%
Abren correo	Hacen clic	Principal riesgo

VULNERABILIDADES

Dispositivos Vulnerables y Configuraciones Inseguras

OWASP Top 10 2021

Las 10 vulnerabilidades web más críticas. **Config. incorrecta** sube al #5.

A05: Config. Seg. Incorrecta

90%

de aplicaciones tienen alguna configuración incorrecta.

Vulnerabilidades Comunes

Sistemas Desactualizados
Sin parches de seguridad. Vulnerables a exploits conocidos.

Credenciales Predeterminadas
Fáciles de adivinar. Listas públicas de defaults.

Puertos Innecesarios
Aumentan superficie de ataque. Acceso no autorizado.

Sistema de Puntuación CVSS

Common Vulnerability Scoring System (0-10)

Crítico	9.0-10.0
Alto	7.0-8.9
Medio	4.0-6.9
Bajo	0.1-3.9
Ninguno	0.0

Errores Humanos

Causa común de configuraciones inseguras:

- No eliminar features innecesarias
- Mensajes de error reveladores
- Cloud mal configurado
- Actualizaciones mal configuradas

IMPACTO SOBRE LA TRIADA CIA

Mapeo de Amenazas contra Principios CIA

Confidencialidad

Amenazas que causan **divulgación no autorizada**:

Phishing
Robo de credenciales

Brechas de Datos
Exposición masiva. Ej: Yahoo (3B cuentas)

Spyware
Espionaje continuo

Integridad

Amenazas que causan **modificación no autorizada**:

Ransomware
Cifrado de archivos. Ej: WannaCry

Modificación de Datos
Alteración maliciosa. Ej: NotPetya ($10B)

Malware Polimórfico
Cambia su código

Disponibilidad

Amenazas que causan **interrupción de servicios**:

DDoS
Saturación de recursos. Ej: Dyn (2016)

Sabotaje
Destrucción física/lógica

APTs
Ataques persistentes. Ej: Stuxnet

Impacto Combinado: Efecto Multiplicador

Amenazas múltiples pueden afectar simultáneamente varios principios CIA:

Ataque APT Avanzado
C: Espionaje / **I:** Modificación / **A:** Sabotaje

Ransomware + Doxxing
I: Cifrado / **C:** Publicación si no se paga

UNIVERSIDAD DE GUADALAJARA
Red Universitaria e Institución Benemérita de Jalisco

CUCEI
CENTRO UNIVERSITARIO DE CIENCIAS EXACTAS E INGENIERÍAS

Tecnologías de Protección

Herramientas y **soluciones técnicas de defensa**

FIREWALL

Firewalls y Cortafuegos

El guardián del perímetro de red

Tipos de Firewalls

Packet Filtering
Inspección básica de headers (capa 3-4).

Stateful Inspection
Tracking de conexiones (estado).

Next-Gen (NGFW)
Inspección profunda (DPI), app awareness.

WAF
Protección específica de apps web.

Arquitecturas

Perímetro
Entrada/salida de la red corporativa.

Host-Based
Software en endpoints (Windows Firewall).

Cloud / Virtual
Firewalls como servicio (FWaaS).

DMZ (Zona Desmilitarizada)
Segmento aislado para servicios públicos.

Capacidades Avanzadas

- **DPI:** Inspección de contenido, no solo headers.
- **App Awareness:** Control por aplicación (Facebook, Dropbox).
- **IPS Integration:** Prevención de intrusos en tiempo real.
- **SSL/TLS Inspection:** Descifrado para inspección.
- **Threat Intelligence:** Feed de IOCs para bloqueo automático.

Reglas y Políticas

Principio de Seguridad

Default DENY. Solo permitir lo estrictamente necesario.

Reglas ACL

Source IP, Dest Port, Protocol. Orden jerárquico.

Casos de Uso

Protección de Perímetro
Control de tráfico internet, NAT, VPN.

Segmentación LAN
Aislamiento de VLANs, control Este-Oeste.

Protección de Aplicaciones
WAF para OWASP Top 10, DDoS mitigation.

PROTECCION ENDPOINT

Antivirus y EDR

De firmas estáticas a detección comportamental avanzada

Evolución: Antivirus → EDR → XDR

Antivirus Tradicional

Detección basada en **firmas**. Escaneo de archivos y comparación con base de datos de malware conocido.

EDR (Endpoint Detection & Response)

Enfoque en **comportamiento y anomalías**. Monitoreo continuo de endpoints con registro y análisis forense.

XDR (Extended DR)

Correlación de datos desde **múltiples fuentes** (endpoint, red, email, cloud) para contexto completo.

Métodos de Detección Modernos

Análisis Heurístico

Identificar malware desconocido por comportamiento sospechoso.

Machine Learning

Modelos entrenados para detectar anomalías y ataques de día cero.

Sandboxing

Ejecución en entorno aislado para análisis dinámico.

Threat Intelligence

Feeds de IOCs para detección proactiva basada en indicadores.

Capacidades de EDR

- **Monitoreo Continuo:** Visibilidad 24/7 de actividad en endpoints.
- **Respuesta Automatizada:** Aislamiento de endpoint, killing de procesos.
- **Análisis Forense:** Registro histórico para investigación post-incidente.
- **Hunting:** Búsqueda proactiva de amenazas avanzadas.
- **Integración SOC:** Alertas en SIEM, orquestación con SOAR.

Gestión Centralizada

Consola Central

Dashboard unificado para visibilidad y control de todos los endpoints.

Políticas de Seguridad

Configuración uniforme de protección y respuesta automatizada.

Reporting y Cumplimiento

Métricas de detección, tiempo de respuesta, estado de cobertura.

RECONOCIMIENTO DE INTRUSOS

Sistemas IDS/IPS

Detección y prevención de intrusos en la red

IDS vs IPS

IDS

Detección: Monitorea y alerta, pero NO bloquea activamente.

- Modo pasivo (span/tap)
- No impacta el tráfico
- Requiere respuesta manual

IPS

Prevención: Detecta y BLOQUEA activamente amenazas en tiempo real.

- Modo inline (activo)
- Acción automática (drop/reset)
- Puede generar falsos positivos

Métodos de Detección

Por Firmas

Patrones conocidos de ataques. Efectivo pero limitado a amenazas conocidas.

Por Anomalías

Comportamiento anormal vs baseline. Detecta amenazas desconocidas.

Tipos de Despliegue

NIDS/NIPS

Network-based. Monitorean tráfico de red en puntos estratégicos.

HIDS/HIPS

Host-based. Agentes en servidores/estaciones. Detectan actividad interna.

Alertas y Correlación

SIEM Integration

Logs centralizados para correlación y análisis forense.

Tuning y Baseline

Ajuste para minimizar falsos positivos/negativos.

Respuesta Automatizada

Bloqueo automático de IPs, aislamiento de hosts.

Importancia: IDS/IPS son componentes esenciales para detección temprana. La combinación de métodos y despliegues proporciona visibilidad completa.

CRIPTOGRAFÍA

Criptografía: Simétrica vs Asimétrica

La ciencia de proteger la información mediante matemáticas

Criptografía Simétrica

Misma clave para **encriptar y desencriptar**. Rápida y eficiente para grandes volúmenes de datos.

Algoritmos Comunes

AES (Advanced Encryption Standard)
Estándar actual. Claves de 128, 192, 256 bits.

ChaCha20
Stream cipher. Rápido en software, usado en TLS.

Desafío: Distribución de Claves
Compartir la clave de forma segura entre partes.

Criptografía Asimétrica

Par de claves pública/privada. Lo que se encripta con una se desencripta con la otra. Elimina el problema de distribución.

Algoritmos Comunes

RSA
Estándar para firma digital y key exchange. Basado en factorización.

ECC (Elliptic Curve)
Igual seguridad que RSA con claves más cortas. Ideal para móviles/IoT.

Ventaja: Distribución Segura
La clave pública puede ser compartida abiertamente.

Aplicaciones Comunes
TLS/SSL, VPN, correo (S/MIME, PGP), cifrado de discos.

Hashing (SHA)
Función unidireccional para integridad. SHA-256, SHA-3.

PKI
Infraestructura de clave pública. Certificados y CAs.

CONEXIONES PRIVADAS

VPN y Túneles Seguros

Conexiones privadas sobre redes públicas

¿Qué es una VPN?

Virtual Private Network: Crea un túnel cifrado sobre una red pública (Internet). Extiende la red privada a ubicaciones remotas de forma segura.

Función: Encriptar tráfico, autenticar usuarios, ocultar IP.

Tipos de VPN

Site-to-Site

Conecta redes enteras (oficina central ↔ sucursal).

Remote Access

Usuarios individuales → red corporativa (teletrabajo).

Protocolos VPN

IPSec

Estándar corporativo. IKEv2 para key exchange.

SSL/TLS

VPN web (cliente web-based). Acceso via navegador.

OpenVPN

Open source, muy configurable. SSL/TLS subyacente.

WireGuard

Moderno, rápido, simple. Criptografía de estado sólido.

Consideraciones

Rendimiento

Overhead de cifrado. Hardware acceleration.

Split Tunneling

Solo tráfico corporativo por VPN. Reduce carga.

Integración

Conectividad con red corporativa (DNS, AD).

MFA

Autenticación fuerte para acceso remoto.

Necesidad: Las VPNs son esenciales para teletrabajo seguro y conectividad entre oficinas. La elección del protocolo depende del balance entre seguridad, rendimiento y facilidad de uso.

SEGMENTACIÓN

Segmentación de Red y VLANs

Divide y protege: aislamiento estratégico del tráfico

Principios de Segmentación

Dividir la red en **segmentos aislados** para contener amenazas y limitar movimiento lateral. Cada segmento tiene sus propias políticas de acceso.

Objetivo: Minimizar superficie de ataque y contener brechas.

VLANs (802.1Q)

Virtual LAN: Segmentación lógica a nivel de capa 2. Múltiples VLANs en un solo switch físico.

Tagging 802.1Q

Etiquetado de tramas para identificar VLAN. Trunk ports.

Segmentación Lógica

Aislamiento de broadcast domains. Seguridad y rendimiento.

Microsegmentación

Segmentación **granular a nivel de workload**. Políticas de acceso entre aplicaciones individuales.

Zero Trust Networking

Verificación antes de acceso. Segmentos de confianza cero.

SDN (Software-Defined)

Control centralizado de segmentación via software.

Políticas de Acceso

Firewall Inter-VLAN

Control de tráfico entre segmentos. Router-on-a-stick o firewall layer 3.

ACLs

Access Control Lists. Reglas de filtrado a nivel de switch/router.

Prevención de Movimiento Lateral

Limitar propagación de amenazas dentro de la red.

Cumplimiento

Segmentación requerida por PCI-DSS, HIPAA.

Rendimiento

Reducir dominios de broadcast, mejorar eficiencia.

BACKUP

Copias de Seguridad y Recuperación

El último recurso cuando todo lo demás falla

Estrategias de Backup

Completo (Full)
Copia de todos los datos. Lento pero simple de restaurar.

Incremental
Solo cambios desde último backup (full o incremental). Rápido.

Diferencial
Cambios desde último full. Restauración más rápida que incremental.

Regla 3-2-1

3 Copias de Datos
Original + 2 backups. Protección contra fallos múltiples.

2 Medios Diferentes
Disco + cinta/cloud. Reduce riesgo de fallo medio.

1 Copia Offsite
Ubicación geográficamente separada. Protección contra desastres.

Almacenamiento

Local
Discos, NAS, SAN. Recuperación rápida.

Cloud
Escalabilidad, durabilidad, geo-redundancia.

Cinta
Largo plazo, económico, air-gap.

Híbrido
Combinación para balance de costo/performance.

Recuperación ante Desastres (DR)

RPO/RTO
RPO: Cuánto dato puedo perder. **RTO:** Tiempo para recuperar servicio.

Testing de Restauración
Backups sin prueba no sirven. Drills periódicos.

UNIVERSIDAD DE GUADALAJARA
Red Universitaria e Institución Benemérita de Jalisco

CUCEI
CENTRO UNIVERSITARIO DE CIENCIAS EXACTAS E INGENIERÍAS

Fundamentos del Riesgo

Análisis, evaluación y **gestión del riesgo**

- Análisis
- Evaluación
- Mitigación
- Gestión

CONCEPTO DE RIESGO

Definición y Componentes del Riesgo

Definición

El riesgo es la **probabilidad de que ocurra un incidente** causando daños a los activos. Es la medida de la exposición a la amenaza.

> "El riesgo cero no existe en ciberseguridad. El objetivo es gestionarlo a niveles aceptables."

Fórmula del Riesgo

$$R = A \times V \times I$$

Riesgo = Amenaza × Vulnerabilidad × Impacto

Si falta algún componente, el riesgo es cero.

Componentes del Riesgo

Amenaza
Evento potencial que puede causar daño

Vulnerabilidad
Debilidad que puede ser explotada

Activo
Recurso de valor para la organización

Impacto
Consecuencias de un incidente

Tipos de Riesgo

Operacional
Procesos

Tecnológico
Sistemas

Humano
Personas

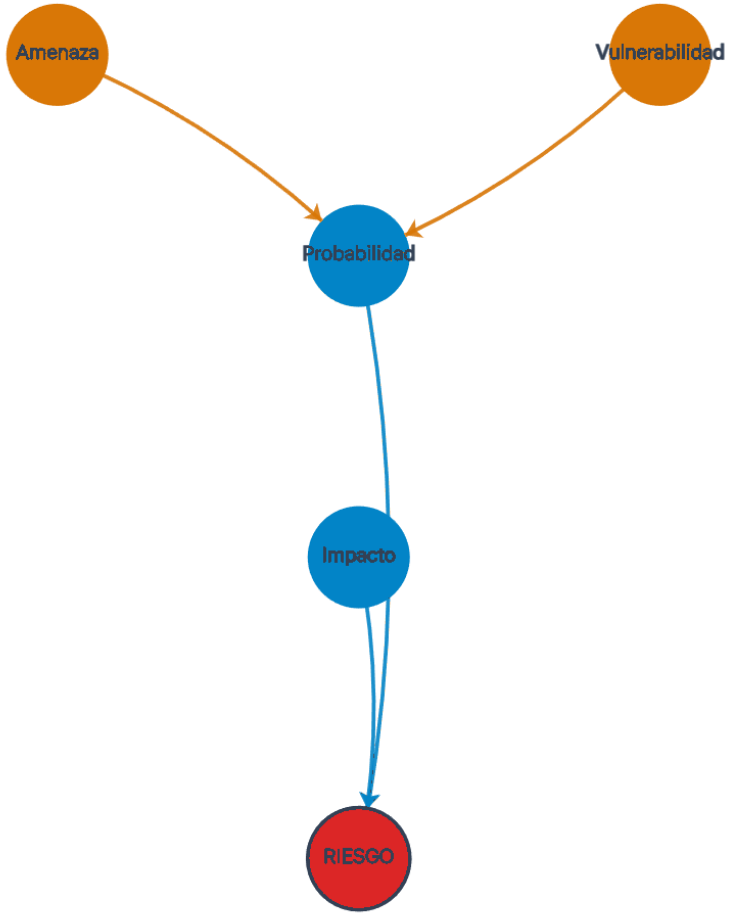
Físico
Instalaciones

Terceros
Proveedores

Cumplimiento
Legales

RELACIÓN ENTRE COMPONENTES

Amenaza + Vulnerabilidad = Riesgo



Modelo Conceptual

Amenaza + Vulnerabilidad
= Probabilidad

↓

Probabilidad × Impacto
= RIESGO

Caso Real: WannaCry (2017)

Amenaza	Vuln.	Impacto
Ransomware	EternalBlue	150 países

Ejemplo Práctico Detallado

Amenaza:
Ransomware (probabilidad 70%)

+

Vulnerabilidad:
Sistema sin parchear (exploit conocido)

+

Impacto:
Datos críticos ($2M de daño)

= RIESGO CRÍTICO

RIESGO INHERENTE VS RESIDUAL

Reducción de Riesgo mediante Controles

Riesgo Inherente

Nivel de riesgo **sin controles de seguridad**. Es el estado original antes de aplicar protección.

Ejemplo:

Servidor web sin firewall, sin parches, sin monitorización = riesgo CRÍTICO.

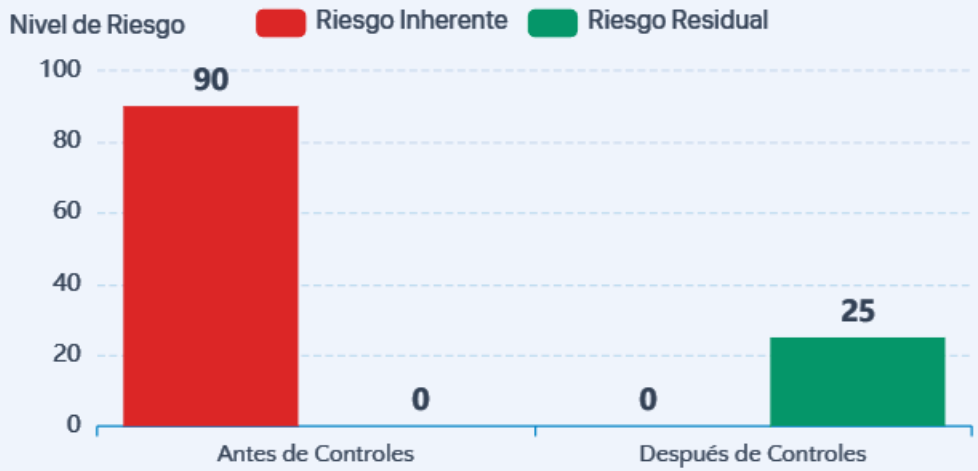
Riesgo Residual

Riesgo que **permanece después de aplicar controles**. Nunca es cero.

Ejemplo:

Con controles: riesgo residual BAJO-MEDIO. Aún existe riesgo de 0-day o error humano.

Proceso de Reducción



Tolerancia al Riesgo

Umbral de riesgo aceptable definido por la organización:

Bajo	Medio	Alto
Conservador	Balanceado	Agresivo

ANÁLISIS DE RIESGOS

Metodología de Análisis de Riesgos en 6 Fases

1 Definir Alcance

Concretar ámbito, activos a analizar y objetivos.

2 Identificar Activos

Inventario completo de activos a proteger.

3 Identificar Amenazas

Enumerar peligros potenciales (ransomware, etc.).

4 Identificar Vulnerabilidades

Detectar debilidades y medidas de protección.

5 Analizar Riesgos

Evaluar y calcular riesgos. Crear matriz.

6 Gestionar Riesgos

Tomar decisiones para mitigar riesgos.

Técnicas de Análisis

Cualitativo

Low/Med/High. Rápido, subjetivo.

Cuantitativo

Valores monetarios. ALE, SLE, ARO.

Herramientas

- Matriz de Riesgo 5x5
- Análisis Bow-Tie
- STRIDE (Microsoft)

UNIVERSIDAD DE GUADALAJARA
Red Universitaria e Institución Benemérita de Jalisco

CUCEI
CENTRO UNIVERSITARIO DE CIENCIAS EXACTAS E INGENIERÍAS

Ética Profesional y Legalidad

Principios éticos, **alcance autorizado** y consecuencias

White Hat | Black Hat | Responsible Disclosure | Marco Legal

ÉTICA PROFESIONAL

Principios Éticos en el Ejercicio de la Ciberseguridad

Tipos de Hackers

White Hat

Autorizado. Mejora seguridad. Ético y legal.

Black Hat

No autorizado. Malicioso. Actividades ilegales.

Grey Hat

Sin autorización pero sin malicia. Línea ética ambigua.

Responsible Disclosure

Proceso ético de revelación de vulnerabilidades: informar al propietario y dar tiempo para corregir antes de hacer público.

Caso Real: Lilith Wittmann (2021)

Encontró vulnerabilidad en app de CDU, informó, y aún así fue denunciada. Caso archivado.

- ✓ No dañar sistemas
- ✓ Proteger privacidad
- ✓ Actuar solo con autorización

ALCANCE AUTORIZADO

Uso Responsable de Técnicas y Herramientas

Rules of Engagement (ROE)

Define **límites contractuales y legales** del trabajo de seguridad. Evita actividades fuera de alcance.

- **Sistemas permitidos:** IPs específicas
- **Horarios:** Test fuera de horas pico
- **Técnicas prohibidas:** DDoS, destructivas

Non-Disclosure Agreement (NDA)

Protección de información sensible descubierta:

> **Confidencialidad:** No divulgar arquitectura de red, vulnerabilidades, datos.

Herramientas de Seguridad

Nmap
Escaneo de puertos

Metasploit
Framework de exploits

Burp Suite
Testing de aplicaciones web

Wireshark
Análisis de tráfico

> **Uso legítimo vs malicioso:** Diferencia clave es el consentimiento.

Metodologías de Pentesting

- **Reconocimiento:** OSINT
- **Explotación:** Gaining access
- **Reporte:** Documentar hallazgos

CONSECUENCIAS

Consecuencias del Uso Indebido de Herramientas

Legales

Procesos Penales

Hacking no autorizado. Multas y prisión.

Demandas Civiles

Daños y perjuicios. Responsabilidad civil.

Marco Legal

CFAA (EE.UU.), GDPR (UE), Leyes locales.

Ejemplo: Morris Worm

Primera condena penal (1988). 3 años de prisión.

Éticas

Pérdida de Credibilidad

Carrera profesional arruinada.

Expulsión de Comunidades

Rechazo en conferencias, foros.

Daño Reputacional

Pérdida de confianza. Difícil recuperación.

Técnicas

Daños a Sistemas

Interrupción de servicios críticos.

Pérdida de Datos

Borrado o corrupción de información.

Interrupción de Negocio

Pérdidas económicas por inactividad.

Ejemplo: Kevin Mitnick Cárcel por hacking no autorizado. Ahora consultor.

UNIVERSIDAD DE GUADALAJARA
Red Universitaria e Institución Benemérita de Jalisco

CUCEI
CENTRO UNIVERSITARIO DE CIENCIAS EXACTAS E INGENIERÍAS

Marcos y Buenas Prácticas

Estándares internacionales: **NIST, ISO 27001, CIS**

- NIST CSF
- ISO 27001
- CIS Controls
- OWASP

MARCOS

Comparativa de Frameworks de Ciberseguridad

NIST CSF

EE.UU. Flexible

1. Identificar
2. Proteger
3. Detectar
4. Responder
5. Recuperar

Ideal para pymes

ISO/IEC 27001

Internacional. SGSI.

- 114 controles Anexo A
- Certificación oficial
- Reconocimiento global
- Procesos de mejora

Para empresas que buscan certificar

CIS Controls

Center for Internet Security

18 controles prioritarios

Implementación en 3 niveles

Guías prácticas

Priorización clara

Recomendado para pymes

MITRE ATT&CK

Base de conocimiento de técnicas adversarias. Para Red/Blue Teams.

OWASP Top 10

Vulnerabilidades web más críticas. Estándar de facto para desarrollo seguro.

COBIT

Gobernanza de TI. Alinea seguridad con objetivos de negocio. Corporaciones.

Comparativa Rápida

Framework	NIST CSF	ISO 27001	CIS Controls	OWASP
	Flexible	Certificable	Práctico	Específico

MARCOS

Gestión de Riesgos y Cumplimiento

Marcos estructurados para la seguridad organizacional

Metodologías de Gestión de Riesgos

NIST RMF (Risk Management Framework)

Proceso de 6 pasos: Categorizar, Seleccionar, Implementar, Evaluar, Autorizar, Monitorear.

ISO/IEC 27005

Estándar internacional para gestión de riesgos de seguridad de la información.

OCTAVE (Carnegie Mellon)

Enfoque en activos críticos, amenazas y vulnerabilidades desde la perspectiva organizacional.

Marcos Regulatorios

GDPR

Protección de datos UE. Multas hasta 4% ingresos.

PCI-DSS

Seguridad de datos de tarjetas de pago.

HIPAA

Información médica en EEUU.

ISO/IEC 27001

SGSI estándar internacional.

Tipos de Análisis

Cualitativo

Categorías descriptivas (Alto/Medio/Bajo). Rápido y económico.

Cuantitativo

Valores numéricos (ALE, SLE). Basado en datos y modelos.

Certificaciones

- Demuestran madurez de seguridad
- Ventaja competitiva y requisitos contractuales
- Framework para auditorías y mejora continua

Cumplimiento vs Seguridad: El cumplimiento es el punto de partida, no el destino. La seguridad efectiva va más allá de los requisitos mínimos.

BUENAS PRÁCTICAS

Principios Fundamentales y Controles Esenciales

Principios de Seguridad

Menor Privilegio
Acceso mínimo necesario.

Defense in Depth
Múltiples capas de defensa.

Need-to-Know
Información solo si es necesario.

Separación de Funciones
Dividir responsabilidades críticas.

Impacto de la Formación

70%

Reducción éxito phishing

Inversión en formación continua del usuario es clave.

Controles Esenciales

Autenticación Fuerte
MFA. Previene el 99.9% de ataques automatizados.

Actualizaciones
Parches regulares. Gestión de vulnerabilidades.

Respaldos Verificados
3-2-1 rule. Protege contra ransomware.

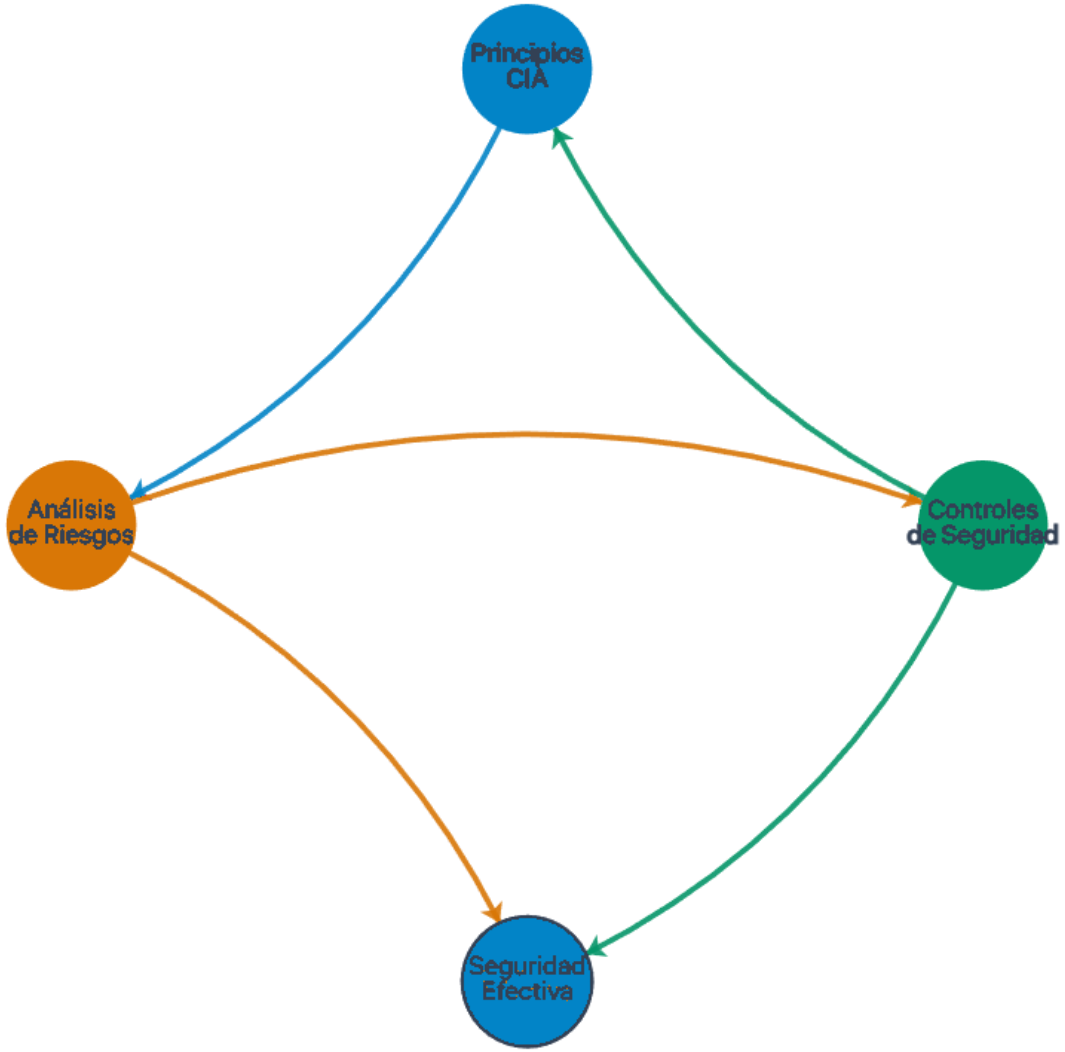
Segmentación de Red
Limita propagación de amenazas laterales.

Monitorización Continua
SIEM, EDR. Detección de anomalías.

Políticas Claras
Uso aceptable, contraseñas, clasificación.

ALINEACIÓN

Conexión entre Principios CIA, Riesgos y Controles



Ciclo de Gestión

1. **Principios CIA:** Qué proteger
2. **Análisis de Riesgos:** Qué puede fallar
3. **Controles:** Cómo proteger

Ejemplo Práctico

Confidencialidad → Riesgo: Acceso no autorizado → Control: MFA

Integridad → Riesgo: Modificación de datos → Control: Firmas digitales

Disponibilidad → Riesgo: Interrupción de servicio → Control: Redundancia

Mejora Continua: PDCA

Plan	Do	Check	Act
Planificar	Implementar	Verificar	Mejorar

BUENAS PRÁCTICAS

Zero Trust: Nunca Confíes, Siempre Verifica

El modelo de seguridad para el mundo moderno

Verificar Explícitamente

Autenticar y autorizar **cada transacción**. No hay confianza implícita basada en ubicación o red.

Privilegios Mínimos

Acceso **justo a tiempo (JIT)** con los permisos mínimos necesarios para la tarea.

Asumir Brecha

Diseñar sistemas asumiendo que ya hay un atacante interno. Minimizar el radio de explosión.

Arquitectura Zero Trust

1. **Identidades**
   Verificación continua de usuarios con MFA y IAM.
2. **Dispositivos**
   Postura y cumplimiento de dispositivos para acceso.
3. **Aplicaciones**
   Control de acceso y monitoreo de apps.
4. **Datos**
   Clasificación, encriptación y DLP.
5. **Red**
   Segmentación micro-perimetral y análisis de tráfico.

Zero Trust vs Tradicional

Modelo Tradicional

- Confianza en la red interna
- Perímetro de seguridad único
- Acceso amplio una vez dentro

Zero Trust

- Ninguna red es de confianza
- Múltiples micro-perímetros
- Verificación continua

Beneficios Clave

- Reducción de superficie de ataque
- Mejor visibilidad y control
- Protección para entornos cloud/híbridos
- Cumplimiento regulatorio mejorado

Implementación: Zero Trust es un viaje, no un destino. Requiere visibilidad completa, políticas dinámicas y cultura de seguridad.

BUENAS PRÁCTICAS

Defensa Profunda en Capas

Múltiples capas de seguridad para máxima protección

Modelo de Defensa Profunda

Estrategia que implementa **múltiples capas de controles de seguridad** para proteger activos. Si una capa falla, las siguientes siguen proporcionando protección.

Filosofía: No depender de una única defensa, crear redundancia y diversidad de controles.

Beneficios

- ✓ Resiliencia: Redundancia ante fallos
- ✓ Diversidad: Diferentes tipos de controles
- ✓ Detección: Múltiples puntos de alerta
- ✓ Retraso: Mayor tiempo para respuesta

Las 5 Capas de Defensa

01 Perimetral

Firewalls, IDS/IPS, DMZ. Primera línea de defensa.

02 Red

Segmentación, VLANs, monitoreo de tráfico interno.

03 Endpoint

Antivirus, EDR, hardening de dispositivos.

04 Aplicación

WAF, code review, WAF, testing de seguridad.

05 Datos

Encriptación, DLP, clasificación y IAM.

Diversidad de Controles

Usar diferentes tipos de controles (técnicos, administrativos, físicos).

Redundancia

Múltiples controles para la misma amenaza (fail-safe).

Resiliencia

Capacidad de recuperación rápida ante incidentes.

BUENAS PRÁCTICAS

Autenticación y Autorización

Quién eres y qué puedes hacer

Autenticación

Proceso de **verificar la identidad** de un usuario, proceso o dispositivo. "¿Eres realmente quien dices

Factores de Autenticación

Algo que SABES
Contraseña, PIN, respuesta secreta

Algo que TIENES
Token, tarjeta, móvil (TOTP, SMS).

Algo que ERES
Biometría: huella, facial, iris.

Uso de **dos o más factores**. Añade capas críticas de seguridad

99.9%	2FA
Reducción de cuentas comprometidas	Mínimo recomendado

Autorización

Proceso de **determinar qué recursos puede acceder** un usuario autenticado. "¿Qué puedes hacer dentro del sistema?"

Modelos de Autorización

RBAC (Basada en Roles)
Permisos asignados a roles ("Admin", "Usuario").

ABAC (Basada en Atributos)
Decisiones basadas en atributos dinámicos.

Privilegios Mínimos
Solo acceso estrictamente necesario.

BUENAS PRÁCTICAS

Políticas de Contraseñas Seguras

La primera línea de defensa de la autenticación

Requisitos de Complejidad

Longitud Mínima

Al menos 12-14 caracteres. Cada carácter añade entropía.

Diversidad de Caracteres

Mayúsculas, minúsculas, números y símbolos.

Prohibición de Términos Comunes

Diccionario, nombres, fechas. Filtros de palabras prohibidas.

Comprobación contra Brechas

Have I Been Pwned. Bloqueo de contraseñas comprometidas.

Gestores de Contraseñas

Herramienta esencial: Generación automática de contraseñas complejas y únicas, almacenamiento seguro y autocompletado.

Beneficios

- Contraseñas únicas por servicio
- Complejidad real (20+ caracteres)
- Cifrado de extremo a extremo

Rotación Periódica

Frecuencia Basada en Riesgo

90-180 días para usuarios estándar. Anual si hay MFA fuerte.

Cambio Forzoso

Forzar cambio tras incidentes de seguridad o acceso sospechoso.

Autenticación Multifactor (MFA)

Obligatoriedad

Requerir MFA para todos los usuarios, especialmente administrativos y acceso remoto.

Métodos Recomendados

TOTP (Google Auth), Push (Duo), WebAuthn/FIDO2. Evitar SMS.

Mitos de Contraseñas: Complejidad extrema sin MFA es menos segura que MFA con passphrase larga y memorable. Priorizar longitud y MFA sobre cambios frecuentes.

BUENAS PRÁCTICAS

Actualizaciones y Parcheo

Cerrar puertas traseras antes de que sean explotadas

Gestión de Vulnerabilidades

Proceso sistemático de **identificar, evaluar y remediar** vulnerabilidades en sistemas y software. El parcheo es el control más efectivo.

Descubrimiento
Inventario de activos, escaneo de vulnerabilidades.

Priorización
CVSS, criticidad del activo, exploits disponibles.

Priorización de Parches

Críticas (0-7 días)
Zero-days, exploits activos, ransomware. Parche inmediato.

Altas (7-30 días)
Vuln. con POC, sistemas expuestos a internet.

Medias/Bajas (30-90 días)
Requieren autenticación local, no explotables remotamente.

Proceso de Parcheo

1. **Evaluación**
   Análisis de impacto, compatibilidad, dependencias.
2. **Testing**
   Entorno de staging. Validación de funcionalidad.
3. **Despliegue**
   Ventanas de mantenimiento, rolling updates, canary.
4. **Verificación**
   Confirmación de instalación correcta, monitoreo.

Automatización

- WSUS/SCCM (Windows), WSUS/MAU (macOS), Ansible (Linux).
- Patch Management Solutions (ManageEngine, Ivanti).
- Container image scanning y patching automático.

Compensaciones: Cuando no se puede parchear inmediato, usar WAF, IPS, compensaciones de red o deshabilitar servicios vulnerables como mitigación temporal.

BUENAS PRÁCTICAS

Concienciación y Formación

El factor humano: el eslabón más fuerte o más débil

Programas de Formación Continua

La **capacitación continua** es esencial. Los usuarios son el primer y último punto de defensa. Un programa integral transforma al factor humano en el eslabón más fuerte.

Onboarding de Seguridad

Formación obligatoria para nuevos empleados antes del acceso a sistemas.

Formación Continua

Cursos trimestrales/anuales. Actualizaciones sobre nuevas amenazas y políticas.

Evaluación de Conocimientos

Tests y certificaciones para medir comprensión. Remediación obligatoria.

Phishing Simulation

Entrenamiento práctico: Campañas simuladas para medir susceptibilidad y proporcionar feedback inmediato.

Métricas Clave

- Tasa de clics en emails de phishing
- Tasa de reporte de phishing
- Mejora tras entrenamiento

Campañas de Sensibilización

Comunicación Constante

Boletines, posters, consejos semanales. Refuerzo de mensajes clave.

Reporting de Incidentes

Canal fácil para reportar actividad sospechosa. Cultura de no castigo.

Cultura de Seguridad: La meta es que la seguridad sea parte del ADN organizacional. Cuando cada empleado es un sensor de amenazas, la organización se vuelve significativamente más resiliente.

BUENAS PRÁCTICAS

Seguridad de Redes Wi-Fi

Protegiendo el aire: el desafío de las redes inalámbricas

Encriptación

WPA3 (2023)

Estándar actual. SAE/Dragonfly (anti-offline dict.), Forward Secrecy.

WPA2 (2004)

AES-CCMP. Seguro si la configuración es correcta, pero vulnerable a KRACK.

Configuración Segura

SSID Ocultos

No transmite nombre de red. Obscurecimiento, no seguridad.

WPS Deshabilitado

Vulnerable a fuerza bruta (PIN). Desactivar siempre.

Segmentación de Redes

Red de Invitados

Aislada de red corporativa. Solo internet. Ancho de banda limitado.

Red Corporativa

Acceso a recursos internos. WPA3-Enterprise, certificados.

IoT/Air-Gap

Dispositivos no corporativos en VLAN separada.

Monitoreo y Detección

Clientes Conectados

Inventario de dispositivos. Detección de no autorizados.

Rogue AP Detection

Detección de puntos de acceso maliciosos. WIDS.

Redes Públicas: En Wi-Fi público, SIEMPRE usar VPN. Nunca asumir que una red es confiable, incluso con contraseña. La seguridad de Wi-Fi es responsabilidad compartida entre admin y usuarios.



UNIVERSIDAD DE GUADALAJARA

Red Universitaria e Institución Benemérita de Jalisco

CUCEI

CENTRO UNIVERSITARIO DE CIENCIAS EXACTAS E INGENIERÍAS

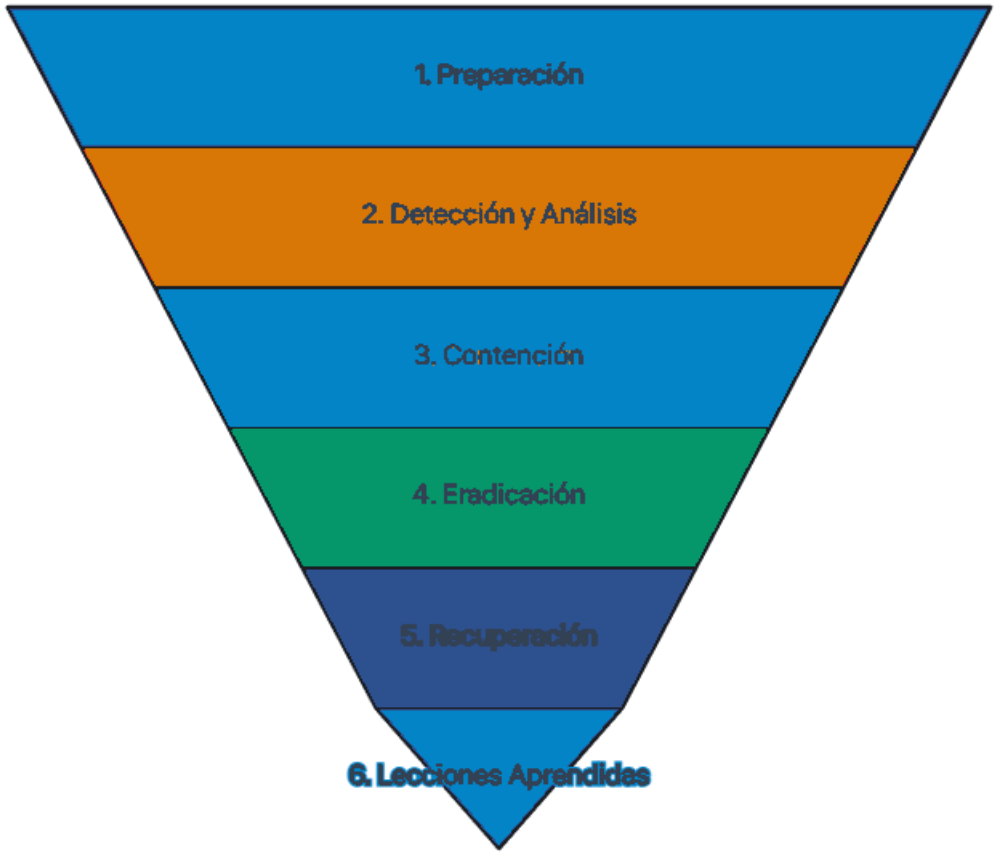
Gestión de Incidentes

Respuesta, contención y **recuperación ante incidentes**

Preparación | Detección | Contención | Recuperación

CICLO DE VIDA

Fases de Gestión de Incidentes de Seguridad



Métricas Clave

MTTD — Min

Mean Time To Detect

MTTR — Min

Mean Time To Respond

Objetivo Principal

Reducir el tiempo de permanencia del atacante:

Dwell Time

Tiempo entre compromiso y detección. Objetivo: <24 horas.

RESPUESTA Y CONTINUIDAD

Planes de Respuesta, Continuidad y Recuperación

Plan de Respuesta a Incidentes

Procedimientos documentados para responder:

- Procedimientos
- Roles Definidos
- Comunicación
- Escalamiento

Plan de Continuidad (BCP)

Mantener operaciones críticas durante crisis:

- Análisis de Impacto
- Procesos Críticos
- Sitio Alternativo
- Recursos Humanos

Plan de Recuperación (DRP)

Restauración de sistemas después del incidente:

- Estrategias de Backup
- RPO y RTO
- Recuperación
- Pruebas Periódicas

Estrategia de Backups: 3-2-1 Rule

3	2	1
copias de datos	medios diferentes	offsite/air-gapped

RESPUESTA Y CONTINUIDAD

Plan de Respuesta a Incidentes

Preparado para lo peor: cuando la seguridad se ve comprometida

01 Preparación

Antes del incidente: Planes, herramientas, entrenamiento. CSIRT definido, comunicación, playbook detallados. Drills periódicos.

02 Detección y Análisis

Identificar el incidente: Monitoreo (SIEM, IDS), reportes de usuarios. Análisis de logs, forense, alcance.

03 Contención

Parar la propagación: Aislar sistemas afectados, preservar evidencia. Decisiones rápidas: desconectar, bloquear, cambiar credenciales.

04 Erradicación

Eliminar la causa: Remover malware, cerrar vulnerabilidades, cambiar todas las credenciales comprometidas. Análisis root cause.

05 Recuperación

Restaurar operaciones: Parchado, hardening, monitoreo intensivo. Validar integridad, reforzar controles.

06 Lecciones Aprendidas

Mejora continua: Post-mortem, documentación, actualización de playbooks. Cultura de aprendizaje, no de culpa.

Preparación es Clave: El tiempo de respuesta determina el impacto. Un plan bien practicado reduce el caos y mejora la toma de decisiones bajo presión.

CSIRT

Computer Security Incident Response Team: Equipo multidisciplinario con roles claros.

Composición

Security, TI, Legal, RRHH, Comunicación, Management.

Comunicación

Interna

Escalamiento, status updates, autorizaciones.

Externa

Clientes, partners, autoridades, GDPR notifications.

Evidencia Digital

Preservación forense: imágenes de disco, logs, memoria. Cadena de custodia para procedimientos legales.

RESPUESTA Y CONTINUIDAD

Análisis de Malware: Estático vs Dinámico

Entendiendo al enemigo: reverse engineering de amenazas

Análisis Estático

Examinar el malware **sin ejecutarlo**. Análisis de código, estructura y contenido.

Técnicas

- **Hashing:** MD5, SHA-1 para identificación única.
- **Strings Analysis:** Extraer URLs, IPs, mensajes.
- **Desensamblado:** Ghidra, IDA Pro. Análisis de assembly.
- **Packing/Obfuscation:** Detectar y desempaquetar.

Ventaja: Seguro, no requiere ejecución. **Limitación:** No muestra comportamiento runtime.

Análisis Dinámico

Ejecutar el malware en **entorno controlado y aislado** (sandbox) para observar su comportamiento.

Técnicas

- **Sandboxing:** Cuckoo, Hybrid Analysis. VMs aisladas.
- **Monitorización:** Process Explorer, Wireshark, Sysinternals.
- **Análisis de Red:** Comunicación C&C, exfiltración.
- **Debugging:** Breakpoints, step-through para entender lógica.

Ventaja: Comportamiento real, detección de técnicas evasivas. **Limitación:** Requiere aislamiento, puede no mostrar todo.

IOCs (Indicadores)

Hashes, IPs, dominios, firmas para detección.

YARA Rules

Patrones para clasificar y detectar familias de malware.

Triage

Análisis rápido para priorizar muestras críticas.

RESPUESTA Y CONTINUIDAD

Gestión de Vulnerabilidades

Encontrar y arreglar debilidades antes de que sean explotadas

Proceso de Vulnerability Management

1. **Identificación**
   Discovery, escaneo automatizado (Nessus, OpenVAS, Qualys).
2. **Evaluación**
   Análisis de criticidad, impacto, exploitabilidad (CVSS).
3. **Priorización**
   Risk-based prioritization. Vuln. críticas primero.
4. **Remediación**
   Parcheo, mitigación, compensación. SLA por criticidad.

Escaneo Automatizado

Credentialed

Con autenticación. Más profundo, detecta parches faltantes.

Non-Credentialed

Sin credenciales. Vista de atacante externo. Limitado.

Vulnerabilidades Críticas

CVSS (Common VSS)

Score 0–10. Base, Temporal, Environmental. Crítica: 9.0–10.0.

EPSS (Exploit Prediction)

Probabilidad de exploit en 30 días. Score 0–1 (0–100%).

Compensaciones

Cuando No Se Puede Parchear

Sistema legacy, downtime crítico, vendor EOL. Controles alternativos.

Controles de Compensación

WAF, IPS, segmentación, ACLs, deshabilitar servicio vulnerable.

Reporting y Métricas: Dashboard de vuln. abiertas, tiempo medio de remediación, cumplimiento de SLA. Datos para reducir ciclo de vida de vulnerabilidades.

RETOS

Inteligencia de Amenazas (Threat Intelligence)

Conocimiento para defender: del reactivo al proactivo

Fuentes de Inteligencia

OSINT
Open Source. Gratuita (CVE, blogs, Twitter). Requiere filtrado.

Comercial
Vendors especializados (FireEye, CrowdStrike). Curada, contexto.

Interna
Logs, SIEM, análisis propio. Más relevante y específica.

Tipos de Inteligencia

Estratégica
Para C-suite: tendencias, motivaciones, impacto negocio.

Táctica
Para SOC: TTPs de atacantes, IOCs, mitigación.

Indicadores de Compromiso (IoCs)

Artefactos de una intrusión: **evidencia observable** de compromiso. Usados para detección y bloqueo.

File IoCs
Hashes (MD5, SHA-1), nombres de archivo, paths.

Network IoCs
IPs, dominios, URLs, User-Agents.

Integración con SOC

Enriquecimiento
Contexto automático para alertas: reputación de IP, hash, familia de malware.

Automatización
Integración con SIEM/SOAR. Bloqueo automático de IOCs maliciosos.

Attribution: Identificar el actor (APT, cibercrimen) proporciona contexto sobre motivación y capacidades, pero es secundario a la detección y respuesta.

RETOS

Seguridad en IoT y Dispositivos Conectados

Cuando todo está conectado, todo es un objetivo potencial

Desafíos Únicos de IoT

Diversidad de Dispositivos

Billones de dispositivos. Múltiples plataformas, OS, arquitecturas.

Recursos Limitados

CPU, memoria, batería. Criptografía y seguridad limitadas.

Longevidad

Dispositivos en campo por años. Firmware sin actualizar. EOL.

Segmentación de Red IoT

Principio fundamental: IoT NUNCA en red corporativa principal. VLAN/firewall separados.

Microsegmentación

Cada tipo de dispositivo en segmento diferente. Control granular.

Zero Trust

Verificar cada dispositivo. No confiar por ubicación de red.

Protocolos Específicos

MQTT

Publish/Subscribe. Autenticación, TLS, ACLs por topic.

CoAP

Constrained App Protocol. UDP, lightweight. DTLS.

Firmware y Actualizaciones

Over-the-Air (OTA)

Updates automáticos, firmados, encriptados. Rollback seguro.

SBOM

Software Bill of Materials. Inventario de componentes para vuln. mgmt.

Casos de Ataques: Mirai (2016) botnet de cámaras. Caso de estudio clásico sobre riesgo de dispositivos con credenciales default. Necesidad de cambiar passwords y segmentación.

RETOS

Tendencias Futuras en Ciberseguridad

El próximo frente de batalla: IA, cuántica y beyond

IA y Machine Learning

IA en Defensa

Detección de anomalías, UEBA, análisis de logs masivos. Reducción de falsos positivos.

IA en Ataques

Phishing personalizado, fuzzing automatizado, evasión de EDR. Arms race.

Zero Trust Evolution

SASE (Secure Access SSE)

Convergencia de networking y seguridad en cloud. ZTNA, FWaaS, SWG.

Identity-Centric Security

El usuario es el nuevo perímetro. Continuous authentication.

Computación Cuántica

Threat to Cryptography

Shor's algorithm romperá RSA/ECC. Timeline: 10-20 años.

Post-Quantum Cryptography

NIST estándarizando algoritmos resistentes (CRYSTALS-Kyber, Dilithium).

OT/ICS Security

IT/OT Convergence

Industrial systems conectados. Stuxnet-style attacks.

Safety over Security

Disponibilidad crítica. Downtime no es opción.

Deepfakes

Impersonación voz/video. Social engineering avanzado.

5G Security

Más superficie de ataque, slicing, edge computing.

SOAR

Automatización de respuesta. Orchestration, playbook execution.

UNIVERSIDAD DE GUADALAJARA
Red Universitaria e Institución Benemérita de Jalisco

CUCEI
CENTRO UNIVERSITARIO DE CIENCIAS EXACTAS E INGENIERÍAS

Construyendo un Futuro Digital Seguro

La ciberseguridad es una responsabilidad compartida que requiere conocimiento técnico, compromiso ético y mejora continua.

Conocimiento

Fundamentos técnicos sólidos

Ética

Compromiso con la responsabilidad

Mejora Continua

Aprendizaje constante

La seguridad no es un destino, es un viaje continuo.

Proteger — Detectar — Responder — Recuperar

MTRO. JOSE DE JESUS SOTO SANCEZ
MAESTRÍA EN SEGURIDAD INFORMÁTICA
CONSULTOR EN CIBERSEGURIDAD

UNIDAD TEMATICA 1

FUNDAMENTOS DE CIBERSEGURIDAD

Fundamentos de Redes y Criptografía Aplicada



UNIVERSIDAD DE GUADALAJARA
Red Universitaria e Institución Benemérita de Jalisco

CUCEI
CENTRO UNIVERSITARIO DE CIENCIAS EXACTAS E INGENIERÍAS